Guía de estudio basada en las prácticas

Introducción a la Ciberseguridad · UNLP · Material de cursada 2026

Práctica 1: criptografía, protección y ocultamiento de información (partes 1 y 2).

Práctica 2: CSIRT, análisis de incidentes, correo, tráfico y malware (partes 1, 2 y 3).

Propósito: comprender la teoría que sirve para resolver los ejercicios, reconocer qué evidencia buscar y practicar preguntas semejantes a las que plantean los trabajos prácticos. No es un solucionario de flags.

Alcance del material

La guía se construyó a partir de los cinco PDF de prácticas y de los diez PDF complementarios de presentación, criptografía, CSIRT, análisis de malware y reversing. La referencia de páginas es la numeración física de cada PDF.

Los ejercicios que dependen de archivos, capturas o servicios del CTF se explican metodológicamente, pero no se atribuyen hallazgos ni flags a archivos que no fueron proporcionados.

Convenciones

- BASE: conceptos o procedimientos presentes en el material de la cátedra.
- AMPLIACIÓN: aclaraciones, fórmulas y ejemplos didácticos complementarios, identificados como tales cuando exceden los PDF teóricos.
- Las respuestas obtenidas consultando registros en Internet, DNS o un CTF pueden cambiar; hay que documentar la fecha y el origen de cada dato.

Cómo usar esta guía

- Leé la explicación de cada unidad y distinguí el concepto de la evidencia observable.
- Intentá contestar las preguntas sin mirar tus notas; verificá después con el PDF citado.
- Ejecutá solo comandos sobre ejemplos propios o archivos autorizados; con malware, privilegiá primero el análisis estático.
- Para cada ejercicio redactá: objetivo, datos recibidos, procedimiento, evidencia, interpretación y límites de la conclusión.

Recorrido y correspondencia con los ejercicios

Unidad	Tema de estudio	Práctica / ejercicios
1–2	Codificación y criptografía clásica	P1.1: 01–04
3–4	Hashes, AES, XOR	P1.1: 05–11
5–6	RSA y Diffie–Hellman	P1.2: 12–16
7–8	Esteganografía y PGP	P1.1: 01g; P1.2: 17–22
9–10	Recursos IP y dominios	P2.1: 01–04
11–13	Email, logs y canales encubiertos	P2.2: 05–12
14–16	Análisis de malware y persistencia	P2.3: 13–19
17	Integración, writeups y repaso	P2.3: 20; resto de writeups

Qué no debe confundirse

- Codificar no es cifrar; cifrar no es hashear; ocultar un dato en una imagen no implica que esté cifrado.
- El email mostrado en From no necesariamente es el origen real; la dirección de un servidor SMTP puede no ser la IP del usuario que envió el correo.
- Un IOC es una pista de detección y no una demostración completa de infección. Una coincidencia de un string no prueba por sí sola conducta maliciosa.
- Las prácticas 1 y 2 NO son prácticas de reversing de ensamblador; los PDF 09 y 10 se usan solo como puente a la inspección de ejecutables.

1. Codificación y reconocimiento de representaciones

Ejercicios de referencia: P1 parte 1: ejercicios 01–02 | Teoría relacionada: 04 Cripto parte 1, pp. 6–8

BASE. Encoding transforma una representación de datos en otra aplicando reglas conocidas sin una clave secreta. Su objetivo es interoperabilidad o transporte, no confidencialidad. En el TP aparecen cadenas numéricas, Base64, hexadecimal, sistemas alfabéticos, Braille e imágenes que obligan a reconocer primero el formato.

Cómo distinguir los formatos

ASCII expresa caracteres mediante valores; decimal y hexadecimal son maneras de escribir números, no cifrados.

Base64 usa típicamente letras, números, +, / y relleno =; el resultado recupera bytes, que todavía podrían necesitar otra interpretación.

A1Z26 asocia letras a posiciones alfabéticas; los separadores pueden representar espacios. Una secuencia numérica puede ser decimal ASCII, códigos Unicode o índices alfabéticos: verificá rangos y contexto.

Ejemplo reproducible

```
printf "IC" | xxd -p
# 4943
printf "SUM=" | base64 -d
# IC
```

Ampliación. Si un valor supera 127, no pertenece al ASCII clásico de 7 bits. En el ítem 01a aparece 241: hay que comprobar qué codificación o conjunto de caracteres representa ese número; no suponer UTF-8 por defecto.

Procedimiento de resolución

1. Reconocer el alfabeto visible, separadores y valores posibles. 2. Formular una hipótesis (ASCII/hex/Base64/etc.). 3. Decodificar una porción y comprobar si produce texto o una segunda capa. 4. Conservar entradas, herramientas y transformaciones utilizadas.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué diferencia existe entre ASCII, Unicode, hexadecimal y Base64?
2. ¿Por qué una cadena Base64 no garantiza el secreto del contenido?
3. Si una secuencia decimal contiene 241, ¿qué precaución tomarías antes de interpretarla como ASCII?
4. ¿Cómo documentarías una decodificación en varias capas y cómo validarías el resultado?

2. Cifrados clásicos: sustitución y transposición

Ejercicios de referencia: P1 parte 1: ejercicios 03–04 | Teoría relacionada: 04 Cripto parte 1, pp. 11–14

BASE. En sustitución se reemplazan símbolos según una regla; en transposición se mantiene el conjunto de caracteres, pero cambia su posición. Los ejercicios introducen César/ROT, la inversión del mensaje, transposición por columnas, Rail Fence y otros esquemas clásicos.

Detección por observación

Una inversión completa como }…{CI suele sugerir invertir la cadena, no necesariamente cambiar letras.

ROT/César desplaza las letras dentro del alfabeto; Atbash reemplaza cada letra por su opuesta. Vigenère utiliza una secuencia de desplazamientos derivada de una clave.

Rail Fence escribe en zigzag sobre varios rieles y recupera el texto leyendo según ese patrón. Columnar organiza el mensaje en columnas y altera su orden de lectura.

Ejemplo didáctico

```
Texto plano: HOLA
Cesar +3: KROD
Invertido: ALOH
```

Ampliación. Para reconocer la transposición, fijate si el texto contiene las mismas letras que el original probable. No garantiza por sí solo el algoritmo: puede haber rellenos, letras cambiadas u otros pasos.

Método de estudio

Reconstruí a mano un César con el alfabeto; compará frecuencia de letras y longitud; probá la transposición sin introducir nuevas letras. Con una pista como 8 × 3, ensayá una grilla de 8 columnas por 3 filas y compará órdenes de llenado y lectura.

Preguntas para estudiar y explicarte en voz alta

1. ¿Cuándo un algoritmo es de sustitución y cuándo de transposición?
2. ¿Qué pistas aportan una cadena invertida y una grilla de dimensiones indicadas?
3. ¿En qué se diferencia César de Vigenère?
4. ¿Por qué los cifrados clásicos no son apropiados para proteger información actual?

3. Funciones hash, diccionarios y salt

Ejercicios de referencia: P1 parte 1: ejercicios 05–08 | Teoría relacionada: 04 Cripto parte 1, pp. 16–20

BASE. Un hash transforma datos de longitud variable en un resumen de longitud fija. Es determinístico y no tiene una operación general de descifrado. Las colisiones son posibles; por eso no se debe interpretar un hash idéntico como demostración matemática de entradas idénticas. Los ejercicios piden identificar algoritmos por longitud y probar candidatos de contraseña.

Cómo interpretar un digest

MD5: 128 bits, 32 caracteres hexadecimales; SHA-1: 160 bits, 40 caracteres; SHA-256: 256 bits, 64; SHA-512: 512 bits, 128.

La longitud orienta pero no identifica de forma única el algoritmo. Un digest hex también puede estar truncado.

El ataque por diccionario calcula hashes de posibles contraseñas y compara. No invierte la función hash. Se puede limitar por un vocabulario probable, como la lista indicada en un reto.

Ejemplo reproducible

```
printf "hola" | md5sum
printf "hola" | sha256sum
# Evitar echo sin -n: agregaria un salto de linea.
```

Para el ejercicio con salt

La práctica especifica MD5($salt.$pass) y un prefijo concreto. La concatenación es parte del esquema: cambiar el orden produce otro resultado.

Ampliación. Un salt público y único impide reutilizar directamente tablas precalculadas entre usuarios; no evita por sí solo la fuerza bruta. En sistemas reales se prefieren funciones de derivación de contraseña lentas como Argon2id, scrypt o bcrypt frente a MD5.

Preguntas para estudiar y explicarte en voz alta

1. ¿Por qué hashear no equivale a cifrar?
2. ¿Cómo distinguirías un MD5 de un SHA-1 o SHA-512 observando solo el tamaño?
3. ¿Qué cambia si se compara MD5(salt + password) con MD5(password + salt)?
4. ¿En qué consiste un ataque por diccionario y qué rol tiene rockyou.txt?
5. ¿Por qué un salt no debe confundirse con una clave secreta?

4. Criptografía simétrica, AES, ECB y XOR

Ejercicios de referencia: P1 parte 1: ejercicios 09–11 | Teoría relacionada: 04 Cripto parte 1, pp. 21–30

BASE. En el cifrado simétrico se utiliza una clave secreta compartida. El material diferencia cifrados por bloques y de flujo; AES cifra bloques de 128 bits y puede operar en distintos modos. ECB procesa bloques iguales bajo una misma clave sin introducir encadenamiento entre ellos, por lo que revela patrones.

AES-128 ECB: qué datos hacen falta

Se necesita algoritmo, longitud real de la clave (16 bytes en AES-128), modo ECB, ciphertext en bytes y tipo de padding, si lo hay.

En el ejercicio 09 el ciphertext se presenta codificado en Base64: primero se decodifica la representación y luego se descifra AES. No son la misma operación.

Ampliación. CBC mezcla el bloque anterior (o un IV en el primero) y evita el patrón más evidente de ECB, aunque hoy se requieren esquemas autenticados para proteger también integridad.

XOR, byte por byte

```
c = m XOR k
m = c XOR k
# Una clave de un byte permite 256 candidatos posibles.
```

Estrategia para XOR de un byte

Decodificar hex a bytes; para cada posible clave entre 0 y 255 aplicar XOR a todos los bytes; evaluar si el texto resultante tiene estructura reconocible. Separar la búsqueda de la clave de la conversión de bytes a texto.

En XOR con clave temporal/autogenerada, averiguar cómo se construye o transmite el flujo de clave antes de intentar ataques indiscriminados. La reutilización de keystream puede producir debilidades.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué diferencia hay entre longitud de bloque y longitud de clave en AES-128?
2. ¿Por qué ECB filtra patrones incluso si la clave no se conoce?
3. ¿Por qué hay que decodificar Base64 antes de descifrar AES?
4. ¿Cuántas claves posibles tiene un XOR de un byte? ¿Cómo comprobar una candidata?
5. ¿En qué se diferencia un cifrado en bloque de uno de flujo?

5. RSA: clave pública, aritmética modular y factorización

Ejercicios de referencia: P1 parte 2: ejercicios 12–15 | Teoría relacionada: P1 parte 1, p. 3 (asimétrica); 04 Cripto parte 1, p. 16 (clasificación). El desarrollo de RSA es AMPLIACIÓN.

La segunda parte de la práctica pide descifrar RSA cuando se conocen p, q, e y C; y luego cuando solo se dispone de n, e y C. Es fundamental distinguir el algoritmo de la tarea de recuperar factores débiles en desafíos educativos.

Derivación paso a paso (ampliación)

Elegir primos p y q, calcular n = p × q y φ(n) = (p−1)(q−1). Elegir e coprimo con φ(n).

Calcular d como inverso multiplicativo de e módulo φ(n), es decir e × d ≡ 1 (mod φ(n)).

Para un entero de mensaje m con 0 ≤ m < n: cifrar c = m^e mod n; descifrar m = c^d mod n.

Sin p y q es necesario otro camino para obtener la clave privada. El TP orienta a la factorización de n; la seguridad de RSA real requiere parámetros adecuados y padding seguro.

Ejemplo numérico didáctico

```
p = 61, q = 53, n = 3233, phi = 3120
e = 17, d = 2753, m = 65
c = pow(65, 17, 3233) # 2790
m = pow(2790, 2753, 3233) # 65
```

Ampliación. El RSA del ejemplo es deliberadamente inseguro por el tamaño de sus factores. En un reto, convertí el entero descifrado a bytes en un orden explícito y revisá la codificación del texto antes de interpretar la respuesta.

Preguntas para estudiar y explicarte en voz alta

1. ¿Cuál es la diferencia entre la clave pública (n,e) y la privada d?
2. ¿Cómo se calcula d a partir de p, q y e?
3. ¿Por qué conocer la factorización de n cambia la posibilidad de descifrar?
4. ¿Cuál es el rol del módulo n en las operaciones de RSA?
5. ¿Por qué el RSA «de libro» del ejercicio no debe trasladarse tal cual a una aplicación real?

6. Intercambio de claves Diffie–Hellman

Ejercicios de referencia: P1 parte 2: ejercicio 16 | Teoría relacionada: P1 parte 1: cifrado asimétrico y problema de distribución de claves (pp. 2–3 y 6–7); el desarrollo DH es AMPLIACIÓN.

La práctica indica un reto de Diffie–Hellman: no consiste en cifrar un mensaje, sino en que dos partes obtengan un secreto compartido a partir de información pública, sin transmitir ese secreto directamente.

Esquema matemático (ampliación)

Ambas partes conocen p y g. Alice elige a secreto y publica A = g^a mod p. Bob elige b secreto y publica B = g^b mod p.

Alice calcula s = B^a mod p y Bob calcula s = A^b mod p. Ambos obtienen el mismo valor s; un observador conoce p, g, A y B.

DH básico no autentica a los participantes: sin otra protección está expuesto a ataques de intermediario.

Ejemplo pequeño

```
p = 23, g = 5, a = 6, b = 15
A = pow(g, a, p) # 8
B = pow(g, b, p) # 19
s = pow(B, a, p) # 2 = pow(A, b, p)
```

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué valores pueden viajar en público y cuáles deben permanecer secretos?
2. ¿Por qué ambos participantes calculan el mismo secreto?
3. ¿DH proporciona cifrado o acuerdo de claves?
4. ¿Cómo podría intervenir un atacante si no se autentica a las partes?

7. Esteganografía, LSB y archivos multimedia

Ejercicios de referencia: P1 parte 1: ejercicio 01g; P1 parte 2: ejercicios 17–18 | Teoría relacionada: P1 parte 1, p. 1 (esteganografía y LSB); la técnica detallada es AMPLIACIÓN.

La esteganografía oculta la existencia de un mensaje dentro de un portador, como imagen, audio o archivo. Se diferencia del cifrado, que transforma el contenido para hacerlo ilegible sin la clave.

Qué inspeccionar en imagen y audio (ampliación)

Metadatos y formato real del archivo; tamaño, firma y posibles datos agregados al final.

Bits menos significativos (LSB): alterar bits de menor peso en muestras o píxeles para incorporar información con cambios visuales pequeños.

Canales, espectrograma y forma de onda en audio; archivos adjuntos u ocultos en contenedores.

La práctica nombra steghide para un ejercicio de imagen y propone otro de sonido. Una contraseña puede ser necesaria para extraer el contenido.

Comandos orientativos

```
file imagen.jpg
exiftool imagen.jpg
steghide info imagen.jpg
steghide extract -sf imagen.jpg
```

No se puede deducir la contraseña del ejercicio 17 ni el texto escondido del 18 con los enunciados únicamente: faltan los archivos publicados en CTFd.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué diferencia hay entre esteganografía y criptografía?
2. ¿En qué consiste esconder bits en LSB?
3. ¿Por qué inspeccionar el formato real y los metadatos antes de extraer?
4. ¿Qué evidencia permitiría defender que un archivo contiene datos ocultos?

8. PGP/GPG: cifrado, firma y confianza

Ejercicios de referencia: P1 parte 2: ejercicios 19–22 | Teoría relacionada: P1 parte 1: criptografía asimétrica (pp. 2–3); 07 CSIRT - Gestión de incidentes, p. 26. El uso detallado de GPG es AMPLIACIÓN.

Los retos combinan generación de claves, descifrado, verificación de mensajes auténticos, cifrado simétrico con passphrase y cifrado asimétrico con una clave pública. Cifrar y firmar proporcionan propiedades diferentes.

Operaciones diferenciadas

Cifrar para una persona: se usa su clave pública; solo la clave privada correspondiente debería permitir recuperar el contenido.

Firmar: se usa la clave privada del emisor; la firma se verifica con su clave pública y debe evaluarse si esa clave realmente pertenece a la persona esperada.

Cifrado simétrico PGP: protege con una passphrase, no exige la clave pública del destinatario.

ASCII armor convierte datos PGP binarios a caracteres imprimibles (marcas BEGIN/END); armor no es por sí mismo cifrado.

Comandos orientativos

```
gpg --gen-key
gpg --list-keys
gpg --decrypt mensaje.asc
gpg --verify firma.asc archivo.txt
gpg --armor --encrypt -r DESTINATARIO archivo.txt
```

Ejercicio 19, episodio 2: validar la firma y la identidad de la clave sin agotar intentos. Ejercicio 20: la palabra de paso que abre un cifrado simétrico puede comprobarse con un diccionario autorizado. Ejercicio 21: enviar el archivo armor resultante, no el texto plano.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué propiedad aporta una firma digital que no se obtiene cifrando?
2. ¿Qué es ASCII armor y qué no garantiza?
3. ¿Qué se necesita para descifrar un mensaje cifrado para una clave pública?
4. ¿Cómo validarías que una firma corresponde a una persona de confianza?
5. ¿Cuál es la diferencia entre una contraseña de PGP simétrico y una clave privada?

Práctica 2 · CSIRT e investigación técnica

En esta parte el objetivo cambia: ya no se trata solamente de recuperar un mensaje. Se aprende a identificar responsables, interpretar evidencias y gestionar incidentes, siguiendo el recorrido de tres partes de la práctica 2.

9. Recursos IP: RIR, NIR, WHOIS y RDAP

Ejercicios de referencia: P2 parte 1: ejercicios 01–02 | Teoría relacionada: 05 CSIRT - Recursos de Internet, pp. 2–13; 07 CSIRT - Gestión de incidentes, pp. 7–10

BASE. Los RIR registran asignaciones regionales de recursos IP y los NIR pueden intervenir en algunos países. En una notificación CSIRT se busca el contacto adecuado, preferentemente el asociado al rol abuse; no necesariamente al dueño del host ni a quien usa una IP en un momento concreto.

Qué devuelve una consulta

Bloque asignado, responsable registrado, país, contactos administrativo, técnico y abuse, y fechas de actualización.

WHOIS suele entregar texto libre con formatos variables; RDAP usa datos estructurados. En algunas asignaciones antiguas una consulta WHOIS genérica puede remitir al RIR incorrecto (material: ejemplo UNLP de bloque legacy/ERX).

Los enunciados incluyen IPv4 e IPv6 y solicitan tanto dirección de contacto como organismo asignador. Son respuestas distintas y hay que verificarlas por separado.

Comandos orientativos

```
whois 163.10.5.66
whois -h whois.lacnic.net 163.10.5.66
# Con cliente RDAP instalado:
rdap 163.10.5.66
```

Procedimiento para un IP del TP

1. Consultar RDAP o WHOIS. 2. Identificar el objeto de red más específico que contiene la IP. 3. Verificar organismo responsable (RIR/NIR). 4. Localizar entidad/contacto de abuso. 5. Registrar fuente, fecha y direcciones consultadas.

No deducir el contacto de un IP por su geolocalización aproximada. Verificar en la registración, que puede diferir entre servicios.

Preguntas para estudiar y explicarte en voz alta

1. ¿Cuál es la función de un RIR y qué cambia cuando interviene un NIR?
2. ¿Por qué RDAP suele ser preferible a WHOIS para automatización?
3. ¿Qué diferencia hay entre contacto administrativo, técnico y abuse?
4. ¿Qué problema pueden producir los bloques legacy/ERX?
5. Si dos servicios devuelven entidades diferentes, ¿qué evidencia guardarías antes de notificar?

10. Dominios: registrant, registrar, registry y abusos

Ejercicios de referencia: P2 parte 1: ejercicios 03–04 | Teoría relacionada: 05 CSIRT - Recursos de Internet, pp. 14–19

BASE. Los actores de un dominio no son equivalentes. Registry gestiona el repositorio del TLD, registrar comercializa y administra registros para registrants, y registrant es quien registró el nombre. En dominios argentinos el material explica que NIC.ar cumple funciones de registry y registrar.

Identificar a quién contactar

Ejercicio 03: encontrar un punto de contacto para quien registró el dominio, que puede estar protegido mediante un servicio de privacidad o formulario.

Ejercicio 04: determinar el contacto de abuso del registrar que vendió el nombre de dominio. No es necesariamente el contacto abuse de la red donde se aloja su web.

Una consulta de un dominio aporta fechas de creación, vencimiento, actualización, nombre del registrar, posibles servicios WHOIS/RDAP y contactos disponibles.

Comandos orientativos

```
whois example.com
# Para DNS (distinto de informacion registral):
dig +short NS example.com
dig +short A example.com
```

Ampliación. Un dominio y una IP son recursos distintos; el responsable del registrar, del hospedaje y del servicio de correo pueden ser organizaciones diferentes.

Preguntas para estudiar y explicarte en voz alta

1. Definí y contrastá registrant, registrar y registry.
2. ¿Por qué un formulario de privacidad puede ser el contacto efectivo del registrant?
3. ¿Por qué la consulta DNS del dominio no alcanza para identificar al registrar?
4. ¿A qué actor dirigís la notificación si la consigna solicita explícitamente al registrador?

11. SMTP, encabezados y suplantación de remitente

Ejercicios de referencia: P2 parte 2: ejercicios 05–07 | Teoría relacionada: 06 encabezados_smtp, pp. 2–17; 07 CSIRT - Gestión de incidentes, pp. 11–12

BASE. La investigación de un correo exige distinguir envelope SMTP, headers y cuerpo. Los headers Received permiten estudiar los saltos de servidor a servidor; From y Reply-To pueden estar elegidos por el emisor y no prueban por sí solos su identidad.

Cómo leer un archivo .eml

To, Delivered-To o X-Original-To pueden servir para detectar a quién se entregó realmente; comparar campos si hay reenvíos y alias.

Consultar registros MX del dominio del destinatario; el valor de prioridad menor se prefiere normalmente para entrega, aunque la traza real puede utilizar otro servidor.

Leer Received desde los servidores de recepción confiables e identificar la IP que se conectó al SMTP receptor. La cadena completa se suele reconstruir cronológicamente de abajo hacia arriba, pero los saltos inferiores pueden ser falsificados.

Diferenciar dirección privada RFC 1918 de IP pública; los 10/8, 172.16/12 y 192.168/16 no identifican directamente una IP pública notificable.

Ejemplo de interpretación

```
Received: from salida.ejemplo (salida.ejemplo [203.0.113.10])
by receptor.ejemplo with ESMTP ...
To: persona@receptor.ejemplo
From: jefe@otraempresa.ejemplo
```

La línea ejemplifica que el servidor receptor afirma haber aceptado una conexión desde 203.0.113.10. Es una IP reservada para documentación, no un IOC real. Se debe verificar qué servidor añadió la línea y qué evidencia de autenticación existe.

Caso de suplantación (ejercicio 07)

Si aparecen mensajes que dicen ser de cuentas del dominio pero el servidor propio no los envió, una hipótesis razonable es spoofing del campo From. No debe afirmarse sin inspeccionar cabeceras reales.

Ampliación: SPF autoriza orígenes SMTP para el dominio de envelope, DKIM verifica firmas de dominio y DMARC define alineación y política respecto del dominio visible en From. Revisar DNS y resultados Authentication-Results, no concluir solo por registros publicados.

```
dig +short MX example.com
dig +short TXT example.com
dig +short TXT _dmarc.example.com
```

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué diferencia hay entre envelope MAIL FROM, header From y Reply-To?
2. ¿Cómo identificás al SMTP que recibió un mensaje y a su par emisor?
3. ¿Por qué no debes aceptar ciegamente cualquier línea Received?
4. ¿Qué función cumple el registro MX?
5. ¿Qué hipótesis explica correos desde usuarios inexistentes de un dominio sin actividad en sus logs?

12. Logs, SSH y clasificación de actividad maliciosa

Ejercicios de referencia: P2 parte 2: ejercicio 08 | Teoría relacionada: 07 CSIRT - Gestión de incidentes, pp. 6–18; 05 Recursos de Internet, pp. 6–12

BASE. El análisis de logs permite separar actividad normal, autenticaciones válidas y ataques fallidos. La clasificación y prioridad CSIRT dependen del evento, activo afectado e impacto posible; una sucesión de intentos fallidos no demuestra acceso exitoso.

Lectura del registro suministrado en el TP

Accepted publickey/password registra una autenticación exitosa para deploy desde la IP que aparece en esa línea; no implica legitimidad absoluta, pero tampoco es evidencia de ataque por sí sola.

Failed password y invalid user indican intentos rechazados; la repetición desde una misma IP contra múltiples usuarios es compatible con fuerza bruta o password spraying/reconocimiento.

CRON root a intervalos y la ejecución de comandos con sudo se analizan en contexto; no suponen automáticamente compromiso.

El caso de varios intentos desde 23.205.189.15 en minutos destaca como patrón sospechoso. Para reportarlo a un responsable, se consulta el registro del recurso IP y su contacto abuse.

Cómo formular la conclusión

Describí hechos observables (fecha, dirección origen, usuarios intentados, resultado). Formulá una clasificación provisional y sus límites; definí evidencia adicional (logs posteriores, eventos de MFA, autenticación y actividad de la cuenta).

Ampliación. Agrupar por IP, ventana temporal, usuarios y resultado evita confundir un intento aislado con una campaña.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué diferencia hay entre Failed password y Accepted password?
2. ¿Qué indica una serie de usuarios variados en segundos desde una misma IP?
3. ¿Se puede afirmar que el host fue vulnerado a partir del log del ejercicio 08? ¿Por qué?
4. ¿Qué datos incluirías en una notificación de abuso a partir de estos registros?

13. Tráfico de red, canales encubiertos y datos ocultos

Ejercicios de referencia: P2 parte 2: ejercicios 09–12 | Teoría relacionada: 07 Gestión de incidentes, pp. 6–10; 06 SMTP, pp. 7–8; aquí hay AMPLIACIÓN para análisis PCAP, Rubber Ducky y ocultamiento Unicode.

En los retos de tráfico se sospecha el uso anormal de protocolos legítimos para transmitir información. Un canal encubierto puede codificar datos en campos, tiempos o tamaños; la sospecha se prueba con patrones reproducibles, no solamente porque existan muchas solicitudes.

PCAP/PCAPNG: procedimiento de investigación (ampliación)

Identificar protocolos y pares origen/destino; observar volumen, frecuencia, tamaños, secuencias y contenido. En ICMP revisar tipos, identificadores, secuencias y payload de solicitudes y respuestas.

En DNS revisar subdominios extrañamente largos, elevada entropía de etiquetas, consultas frecuentes y respuestas anómalas. En HTTP u otros protocolos también puede haber campos inesperados.

Extraer y ordenar los fragmentos según su secuencia temporal o identificador; analizar si están representados en ASCII, hex, Base64 u otra codificación antes de reconstruir un mensaje.

Comandos orientativos de lectura

```
tshark -r trafico.pcapng -q -z io,phs
tshark -r trafico.pcapng -Y "icmp" -T fields \
-e frame.time -e ip.src -e ip.dst -e data.data
tshark -r trafico.pcapng -Y "dns.qry.name" \
-T fields -e frame.number -e dns.qry.name
```

Dispositivos HID e invisibles (ampliación)

Un USB Rubber Ducky puede comportarse como teclado HID e introducir secuencias automáticas de teclas. El archivo referenciado debe inspeccionarse como instrucciones potenciales y no ejecutarse.

En un reto con texto aparentemente vacío, mirar caracteres Unicode invisibles o de ancho cero, metadatos y diferencias binarias (por ejemplo usando xxd); ausencia visual de letras no implica archivo vacío.

El enunciado del ejercicio 12 contiene espacios llamativos. Sin el recurso completo y una inspección de bytes no se debe inventar la codificación usada ni una flag.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué diferencia hay entre un ping ordinario y una sospecha fundamentada de canal encubierto?
2. ¿Qué campos observarías al investigar exfiltración por ICMP?
3. ¿Cómo detectarías datos escondidos en consultas DNS?
4. ¿Por qué es importante mantener orden y dirección de los paquetes al reconstruir un mensaje?
5. ¿Qué es un dispositivo de inyección de teclas y por qué no debe ejecutarse su payload?
6. ¿Cómo comprobarías si un texto visualmente vacío contiene Unicode invisible?

14. Análisis estático de malware y sus IOC

Ejercicios de referencia: P2 parte 3: ejercicio 13 | Teoría relacionada: 08 Analisis_de_malware, pp. 1–33; 09 Reversing, pp. 3 y 10–13 (lectura complementaria)

BASE. Antes de ejecutar una muestra sospechosa, el análisis estático obtiene hashes, strings, cabeceras, imports, secciones y recursos. El objetivo es valorar indicios de malicia e identificar IOC para buscar muestras o sistemas afectados.

Matriz de evidencia del análisis

Hash criptográfico: sirve para identificar una muestra exacta; cualquier modificación del archivo suele cambiarlo.

Strings: posibles URLs, IP, nombres de archivos, comandos o rutas; pueden ser falsos positivos o datos no usados durante la ejecución.

PE: examinar cabecera, secciones (.text, .rdata, .data, .rsrc), importaciones y recursos con CFF Explorer o herramientas equivalentes.

Importar URLDownloadToFile/InternetOpen puede sugerir descarga o comunicación. Una importación indica capacidad o posibilidad, no prueba la ejecución concreta de esa acción.

Empaquetado/ofuscación: poca cantidad de strings, imports mínimos y tamaños anómalos entre raw y virtual size pueden ser señales, no confirmación.

Comandos orientativos sin ejecutar la muestra

```
file muestra.exe
sha256sum muestra.exe
strings -a -n 6 muestra.exe | head
# Para strings UTF-16LE, segun la herramienta:
strings -el muestra.exe | head
```

Persistencia como hipótesis

Buscar referencias a run keys, servicios, tareas u otros mecanismos. Si aparecen rutas como HKCU\...\Run, justificar por qué sugieren autoejecución.

La práctica pide cómo parece que intenta persistir: en estático usar expresiones condicionadas y evidencia concreta. Para confirmar la acción generalmente hace falta trazado dinámico.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué constituye un IOC de archivo, proceso, registro y red?
2. ¿Por qué un hash permite localizar una muestra pero no necesariamente toda su familia?
3. ¿Qué secciones PE revisarías y qué información suelen contener?
4. ¿Qué significa que un ejecutable importe URLDownloadToFile?
5. ¿Por qué ofuscación o packer no son prueba concluyente de malware?

15. Análisis dinámico, descargas y persistencia

Ejercicios de referencia: P2 parte 3: ejercicios 14–16 | Teoría relacionada: 08 Analisis_de_malware, pp. 34–57

BASE. El análisis dinámico compara procesos, filesystem, registro y red antes y después de una ejecución controlada. La teoría recomienda máquinas virtuales aisladas, snapshots limpios, sin conexión a la red institucional ni carpetas compartidas con equipos reales.

Protocolo de análisis seguro

1. Registrar hash y estado inicial. 2. Preparar VM aislada con snapshot; no usar el sistema personal. 3. Activar registro de procesos, filesystem, registry y red (por ejemplo, Procmon, Regshot, Autoruns, Wireshark).

4. Ejecutar solo dentro del laboratorio habilitado. 5. Correlacionar procesos creados, archivos descargados, URLs, claves y conexiones. 6. Restaurar snapshot para cada prueba.

La teoría advierte que no todos los caminos de ejecución se activan en una corrida. Un malware puede depender de red, fechas, argumentos u otros requisitos.

Persistencia frecuente en Windows

HKCU\Software\Microsoft\Windows\CurrentVersion\Run: autoejecución al iniciar sesión del usuario, habitualmente sin privilegios de administrador para escribir en HKCU.

HKLM\System\CurrentControlSet\Services: servicios del sistema; su creación suele requerir privilegios elevados.

Otras técnicas que utilicen GUID/CLSID, COM u otras claves deben identificarse por la ruta y el uso exactos. La pista «The art of persistence» del ejercicio 15 no prueba por sí misma una técnica particular.

Qué entregar por los ejercicios 14–16

Armar línea temporal: programa iniciado -> proceso(s) hijos -> URI visitada -> archivo creado (nombre y ruta absoluta) -> cambio de persistencia.

Si hay conexión fallida, registrar IP:puerto, error y momento; luego documentar dominio/URL de la conexión exitosa, solicitud, respuesta y qué contenido efectivamente salió.

Un GUID es un identificador de 128 bits: debe copiarse exactamente y vincularse con la clave/objeto donde se observó. No inferirlo por semejanza a otros GUID.

Preguntas para estudiar y explicarte en voz alta

1. ¿Cuándo conviene usar Regshot, Autoruns y Procmon?
2. ¿Qué evidencia demuestra persistencia y cómo se distingue de una referencia textual?
3. ¿Qué diferencia hay entre HKCU y HKLM respecto de permisos y alcance?

4. ¿Qué datos buscarías para recuperar la URL y la respuesta de un servidor?
5. ¿Por qué un único análisis dinámico puede ser incompleto?

16. Scripts ofuscados, documentos y hojas de cálculo

Ejercicios de referencia: P2 parte 3: ejercicios 17–19 | Teoría relacionada: 08 Analisis_de_malware, pp. 13–16, 27–40 y 48–57; 09 Reversing, pp. 3–4 (apoyo)

Los ejercicios introducen un .vbs ofuscado, un documento .docm y una planilla .xls. Se debe separar el contenido aparentemente legítimo de su comportamiento potencialmente peligroso. La ofuscación es el ocultamiento o transformación del código para dificultar su lectura; no significa necesariamente cifrado seguro.

Cómo estudiar sin activar el contenido

VBS: localizar concatenaciones, códigos de caracteres, evaluaciones dinámicas, cadenas codificadas y rutas; reconstruir texto en etapas sin ejecutar expresiones peligrosas.

DOCM: puede contener macros VBA; examinar contenedor, módulos, eventos AutoOpen/Document_Open y llamadas sensibles antes de habilitar contenido.

XLS: las planillas antiguas pueden contener macros VBA o XLM; examinar estructura y fórmulas, hojas ocultas, nombres definidos, enlaces externos y posibles arranques automáticos.

Ampliación. Herramientas como oletools u olevba permiten inspección estática; la herramienta no reemplaza el análisis de qué evidencia soporta cada conclusión.

Chequeos generales

```
file sospechoso.docm
sha256sum sospechoso.docm
# Inspeccion especializada en entorno de laboratorio:
olevba sospechoso.docm
```

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué señales permiten distinguir ofuscación de una cadena de texto normal?
2. ¿Qué clases de activadores pueden disparar una macro de documento?
3. ¿Qué diferencias de análisis considerarías entre DOCM y XLS?
4. ¿Por qué no hay que habilitar macros para «ver qué pasa» en la computadora personal?
5. ¿Qué indicios vincularían un documento con una descarga de malware?

17. Integración y elaboración de writeups

Ejercicios de referencia: P2 parte 3: ejercicio 20; todos los ejercicios marcados Writeup | Teoría relacionada: 02 Writeup example, pp. 1–5; 07 Gestión de incidentes, pp. 7–10 y 18–24

BASE. La cátedra pide documentar el proceso de resolución con enunciado, solución, reflexión y flag. El writeup debe hacer reproducibles las conclusiones: distinguir observaciones, hipótesis y datos obtenidos de herramientas.

Plantilla recomendada para cada reto

Enunciado: nombre, práctica/ejercicio, categoría, dificultad, adjuntos y pistas.

Solución: qué se recibió, por qué se eligió cada prueba, comando o herramienta usada, resultados, capturas relevantes y validación.

Reflexión: qué se aprendió, qué falló, qué se haría distinto y hasta dónde llega la evidencia.

Flag: solamente el valor realmente recuperado y verificado, no supuesto.

Ejemplo de razonamiento sin inventar resultados

Observación: «El archivo importa una rutina de descarga». Inferencia justificable: «Podría descargar contenido». Conclusión que requiere prueba adicional: «Descargó un archivo de tal URL».

Observación: «Hay cinco Failed password desde una IP». Inferencia: «Patrón compatible con intentos automatizados». Conclusión injustificada: «El atacante accedió» sin un evento Accepted u otras evidencias.

Preguntas para estudiar y explicarte en voz alta

1. ¿Qué evidencia hace reproducible un resultado de WHOIS/RDAP?
2. ¿Cómo separarías hipótesis, observación y conclusión en un análisis de malware?
3. ¿Qué incluirías en la reflexión de un ejercicio donde la primera estrategia falló?
4. ¿Por qué un writeup con una flag pero sin metodología no cumple el objetivo formativo?

Banco de repaso integrado

Intentá explicar estos casos sin recurrir a nombres de herramientas como única respuesta. Cada caso combina dos o más temas de la cursada.

Caso A · Representaciones

Recibís una cadena Base64 que al decodificar se convierte en caracteres hexadecimales. ¿Qué dos transformaciones harías y cómo demostrarías que el resultado no era todavía texto cifrado?

Caso B · Integridad y contraseñas

Dos archivos distintos dan un digest MD5 idéntico. ¿Por qué es posible? ¿Qué implicación tiene para integridad? ¿Por qué cambiar una contraseña por su hash MD5 no es una defensa suficiente?

Caso C · Correo

Un mensaje dice venir de una cuenta institucional inexistente. El campo Reply-To lleva a un buzón externo y el SMTP receptor observa una IP ajena. ¿Qué campos conservarías y a qué responsables notificarías?

Caso D · Malware

Un ejecutable contiene una URL, una Run key y referencias a descarga. ¿Cuáles son IOC estáticos? ¿Qué observaciones dinámicas necesitarías para afirmar que descargó y persistió?

Caso E · PCAP

Un equipo genera ICMP periódico. ¿Cómo probarías que hay datos ocultos sin confundir un patrón de monitoreo legítimo con exfiltración?

Caso F · RSA y PGP

¿Por qué poseer una clave pública basta para cifrar al destinatario, pero no para firmar en su nombre? ¿Dónde se usa la factorización en el RSA didáctico?

Caso G · Investigación

Una IP de un log aparece asignada a una empresa extranjera, mientras un dominio involucrado utiliza un registrar de otro país. ¿Por qué no se trata necesariamente de información contradictoria?

Criterios de autocorrección

- Respondí con definiciones precisas, no solamente con nombres de programas.
- Justifiqué qué parte de la evidencia es confiable y cuál podría ser falsificada o incompleta.
- Distinguí seguridad de confidencialidad, integridad, autenticidad y disponibilidad.
- Identifiqué al responsable correcto (RIR/NIR, registrant, registrar, operador de SMTP, contacto abuse).
- Expliqué por qué los hallazgos de archivos no adjuntos o servicios no consultados no pueden afirmarse.

Mapa rápido de fuentes y páginas

Cada referencia apunta a páginas internas del PDF original. Se mencionan los materiales de reversing solo como apoyo conceptual para la lectura de ejecutables; no sustituyen los temas de las prácticas 1 y 2.

01 Presentacion · pp. 4–9: modalidades y objetivos de la cursada.

02 Writeup example · pp. 1–5: enunciado, solución, reflexión, flag.

03 Conceptos Básicos · pp. 3–8: CIA, amenazas, riesgos y ataques.

04 Cripto parte 1 · pp. 6–14: encoding y criptografía clásica; 16–30: hash y simétrica.

05 CSIRT - Recursos de Internet · pp. 3–13: asignaciones, WHOIS, RDAP; 14–20: nombres de dominio y notificación.

06 encabezados_smtp · pp. 2–10: DNS/MX, envelope, headers, Received; 11–17: SMTP y falsificación.

07 CSIRT - Gestión de incidentes · pp. 6–18: incidente, pertinencia, prioridad y notificaciones; 22–26: prácticas y PGP.

08 Analisis_de_malware · pp. 3–33: IOC, estático, PE y packers; 34–57: dinámico, registry y herramientas.

09 Reversing · pp. 3–4, 9–13: límites de reconstrucción y análisis estático/dinámico.

10 reversing_2 · pp. 2–6: mapa de memoria y bytes; no es temario central de estos TP.

Práctica 1 - Criptografía - Parte 1 · pp. 1–8: enunciados de ejercicios 01–11 y explicaciones base.

Práctica 1 - Parte 2 · pp. 1–4: ejercicios 12–22, RSA/DH/esteganografía/PGP.

Práctica 2 - Parte 1 · pp. 1–7: ejercicios 01–04 y explicación sobre IP/dominios.

Práctica 2 - Parte 2 · pp. 1–3: ejercicios 05–12 sobre mail, logs, PCAP y datos ocultos.

Práctica 2 - parte 3 · pp. 1–3: ejercicios 13–20 sobre malware y documentos.

Límites específicos que debes tener presentes

- No se incluyeron mail_1.eml, mail_2.eml, capturas .pcapng, ejecutables, ofuscado.vbs, reto.docm, planilla .xls, audios, imágenes ni archivos del CTFd.
- Por lo tanto, esta guía explica cómo analizarlos, pero no determina URLs, claves, GUID, hashes de muestra, respuestas SMTP ni flags particulares.
- Las consultas de asignación de IP o dominio son dependientes de los registros actuales. Los ejemplos del PDF teórico son históricos y deben contrastarse si se usan para notificaciones reales.
- En el material recibido, la teoría de RSA, Diffie–Hellman y esteganografía es mucho más breve que los ejercicios. Las secciones respectivas incluyen ampliaciones didácticas explícitas.